Document ID: VIB-SEC-INC-025 Classification: INTERNAL CONFIDENTIAL (External Extracts Permitted) Effective Date: 2024-04-01 Version: 6.2

Document Owner: Enterprise Chief Information Security Officer (CISO)

Security Incident Response Plan: VI Business (India)

1. Executive Purpose and Document Scope

The Security Incident Response Plan (SIRP) dictates the rapid, coordinated actions executed by the VI Business (India) Security Operations Center (SOC) during a suspected or confirmed cyber breach.

This document serves as proof to enterprise customers (particularly within the highly regulated BFSI sector) that our 24x7x365 threat monitoring is backed by an audited, CERT-In aligned containment methodology, designed primarily to protect sovereign customer payload and core infrastructure availability.

2. Definitions, Assumptions, and Applicability

Definitions:

- **CSIRT:** Cyber Security Incident Response Team.
- **IoC:** Indicator of Compromise.
- **CERT-In:** Indian Computer Emergency Response Team.
- **Ransomware:** Cryptovirology attack threatening to publish or block data access.

Assumptions:

- The SIRP applies to VI-managed networking and security infrastructure. It does not magically resolve vulnerabilities originating from unmanaged, customer-owned LAN segments or user endpoints.
- "Time to Contain" SLAs represent "Best Effort" during Zero-Day (previously unknown) vulnerability exploitation.

Applicability:

- **Target Audience:** Enterprise CISO, Customer IT Directors, Bid Writers answering "Incident Handing" RFP chapters.
- **Scope:** Managed SOC, Cloud API Gateways, and the core VI Tier-III MPLS/SD-WAN network.

3. Incident Classification (Triage Severity)

The SOC parses millions of daily SIEM logs. When an alert triggers, the L1 Analyst categorizes it into a triage severity matrix within 15 minutes.

Classification	Definition	Initial Response SLA	Minimum Escalation Authority
S1 (Critical)		15 Minutes	Enterprise CISO

Classification	Definition	Initial Response SLA	Minimum Escalation Authority
	Active, confirmed lateral movement. Ransomware detonation. Core network compromise.		
S2 (High)	Verified external exploit attempt against a known unpatched perimeter vulnerability. Phishing campaign yielding credential theft.	30 Minutes	Head of SOC Operations
S3 (Medium)	Malware detected and auto-quarantined by endpoint EDR. Policy violation (e.g., unauthorized scanning).	2 Hours	SOC Shift Lead (L2)
S4 (Low)	Generic threat intelligence feed noise. Suppressed port-scan attempts dropped by edge firewall.	Next Business Day	L1 SOC Analyst

4. Roles and Responsibilities (The CSIRT)

During an S1 or S2 incident, the standard SOC hierarchy pivots into the formal CSIRT.

- **Incident Commander (CISO/Head of SOC):** Retains absolute authority over containment strategy. Authorizes emergency, service-disrupting firewall drops.
- **Incident Handlers (Tier 2/3 Threat Hunters):** Execute the technical forensic analysis. Correlate logs in Splunk/QRadar; extract malicious payloads for sandbox detonation.
- **Communications Lead (Customer Success):** The exclusive point of contact managing the crisis bridge with the affected Customer IT team. Engineers are forbidden from communicating unverified technical hypotheses directly to the customer.

5. Containment, Eradication, and Recovery Process

The CSIRT follows a strict chronological progression:

5.1 Identification

- SIEM heuristics, EDR behavioural triggers, or external Threat Intel feeds (e.g., FireEye, CrowdStrike) flag anomalous behavior.
- L2 Analysts verify the event is a genuine positive, not a system misconfiguration.

5.2 Containment (Damage Control)

- **Short-Term:** Isolate the infected subnet or SD-WAN branch. Disconnect physically or impose strict "Deny-All" Virtual Routing and Forwarding (VRF) rules at the core. *Priority: Prevent lateral spread, even if it causes temporary branch downtime.*
- **Long-Term:** Rebuild active directories, rotate all Service Account credentials, and enforce emergency out-of-band firmware patching.

5.3 Eradication and Recovery

- Deep forensic scans determine exactly *how* the actor breached the perimeter.
- Systems are patched, tested in a segregated sandbox, and brought back online gradually to monitor for resurgence.

6. Evidence Handling (Chain of Custody)

In the event of civil litigation or regulatory enforcement, digital evidence must survive scrutiny in an Indian court of law (per the IT Act 2000).

- **Forensic Images:** The CSIRT creates bit-for-bit, write-blocked hard drive images of compromised uCPE or core servers prior to initiating eradication.
- **Immutable Logs:** Firewall transit logs and authentication attempts are hashed (SHA-256) and stored in encrypted AWS S3 cold storage to prevent post-breach tampering by the threat actor.
- **Custody Log:** A physical/digital ledger recording exactly who accessed the forensic payload and when.

7. Customer Communication Rules and Reporting Obligations

- **Mandatory Notification:** For S1/S2 incidents directly impacting customer payload or specific tenant orchestrators, the VI Communications Lead notifies the Customer's designated CISO/Security Lead within 2 hours of verified identification.
- **CERT-In Mandate:** Under the April 2022 CERT-In directives, VI Business is legally mandated to report specific severe cyber incidents (e.g., targeted scanning, ransomware, massive DDoS) to the national agency within 6 hours of noticing them. *This is a sovereign legal obligation and transcends any non-disclosure agreements (NDAs) signed with the customer.*

8. Post-Incident Review (PIR)

Within 5 business days of stabilizing an S1/S2 incident, the CSIRT convenes a formal PIR.

- **Deliverable:** A formal "Root Cause Analysis (RCA)" document is generated, outlining the timeline of the attack, the initial vulnerability vector, and the permanent control enhancements (e.g., tightening standard firewall baselines) implemented to prevent recurrence.

9. Constraints, Exclusions, and Dependency Notes

- **Customer "Right to Audit":** Post-breach, customers frequently demand immediate physical access to the Pune SOC. This is explicitly denied to protect the confidentiality of other multi-tenant clients. Customers receive the sanitized RCA and formalized compliance statements.

10. Proposal-Use Guidance

- **Winning Trust:** When answering an RFP's "Incident Response" matrix, do not state "We take security seriously." Paste Section 3 (Classification) and Section 7 (Reporting Obligations) to demonstrate a legally mature, CERT-In compliant apparatus.

11. Governance and Ownership

- **Owner:** Enterprise Chief Information Security Officer (CISO)
- **Reviewers:** Head of Enterprise Legal, National Head of Corporate Risk and Compliance.
- **Update Cadence:** Annual, verified via external "Red Team" penetration testing exercises.